



# Vulnerability Assessment & Penetration Testing (VAPT) Report

Unity Health

25 April 2025



## TABLE OF CONTENTS

|          |                                               |           |
|----------|-----------------------------------------------|-----------|
| <b>1</b> | <b>EXECUTIVE SUMMARY .....</b>                | <b>3</b>  |
| <b>2</b> | <b>SCOPE OF TESTING .....</b>                 | <b>3</b>  |
| <b>3</b> | <b>METHODOLOGIES USED .....</b>               | <b>3</b>  |
| 3.1      | NMAP / ZENMAP.....                            | 3         |
| 3.2      | NESSUS .....                                  | 3         |
| 3.3      | GREENBONE ENTERPRISE .....                    | 4         |
|          | <b>STAY ONE STEP AHEAD OF ATTACKERS .....</b> | <b>4</b>  |
| 3.4      | OWASP.....                                    | 5         |
| 3.5      | BRUTE FORCE.....                              | 5         |
| <b>4</b> | <b>INFRASTRUCTURE.....</b>                    | <b>6</b>  |
| 4.1      | PRODUCTION SERVER – 41.76.215.242 .....       | 6         |
| 4.2      | TEST SERVER – 41.76.215.103 .....             | 11        |
| 4.3      | VP SERVER – 41.76.215.103 .....               | 14        |
| 4.4      | ODS SERVER – 41.76.213.162.....               | 16        |
| <b>5</b> | <b>REPORTING CONCLUSION .....</b>             | <b>19</b> |
| <b>6</b> | <b>AUDITORS .....</b>                         | <b>19</b> |



## 1 EXECUTIVE SUMMARY

The objective of this assessment was to identify security vulnerabilities, business logic flaws, and missing best security practices. The tests were conducted from the perspective of an attacker or malicious user, without causing any disruption to the functionality or performance of the application or network. Additionally, a comprehensive scan of the infrastructure was performed to simulate a real-world attack scenario, such as an internal network breach or exposure on a shared public subnet.

The assessment, including scans and brute-force testing, was carried out over seven (7) business days to ensure a thorough and methodical audit. These scans also examined unidentified connectivity options, such as packet SYN requests.

## 2 SCOPE OF TESTING

Security assessments include testing for security loopholes in the scope defined below. Apart from the following, no other information was provided. Nothing was assumed at the start of the security assessment. The following scope of servers were covered under the security audit:

- Production Server - 41.76.215.242
- Test Server - 41.76.215.103
- VP Server - 41.76.215.27
- ODS Server - 41.76.213.162

## 3 METHODOLOGIES USED

Sautech performed various audit techniques that includes the following:

### 3.1 Nmap / Zenmap

Nmap, short for Network Mapper, is a free and open source tool used for vulnerability checking, port scanning and, of course, network mapping. Despite being created back in 1997, Nmap remains the gold standard against which all other similar tools either commercial or open source, are judged.

To deploy Nmap, users originally had to have some advanced programming skills, with the introduction of the Zenmap tool for Nmap, which adds a graphical interface that makes launching the program and analysing the returned output it generates much more accessible.

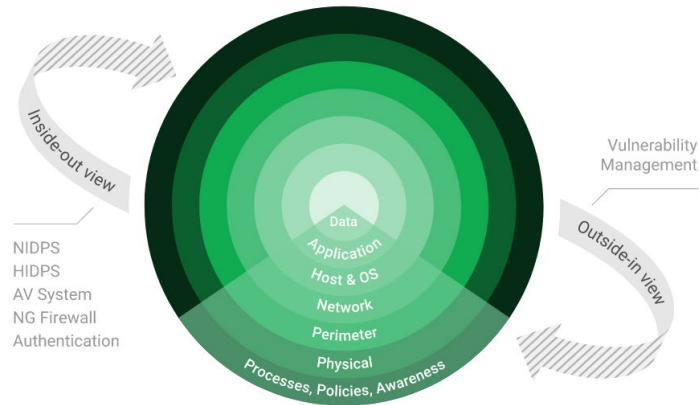
### 3.2 Nessus

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network. It does this by running over 1200 checks on a given computer, testing to see if any of these attacks could be used to break into the computer or otherwise harm it.



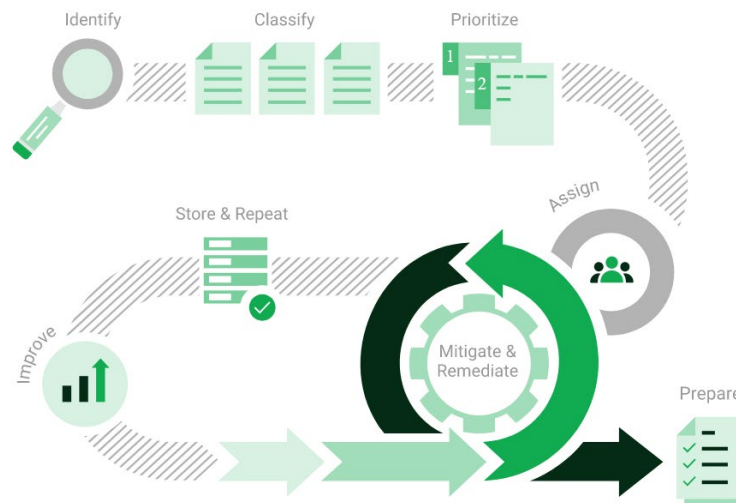
### 3.3 Greenbone Enterprise

Greenbone is the world's most widely used vulnerability management provider.



## STAY ONE STEP AHEAD OF ATTACKERS

IT security is a process – Open Source vulnerability management provides the foundation. Once you know where the chinks are in your armor, you can do something about them.

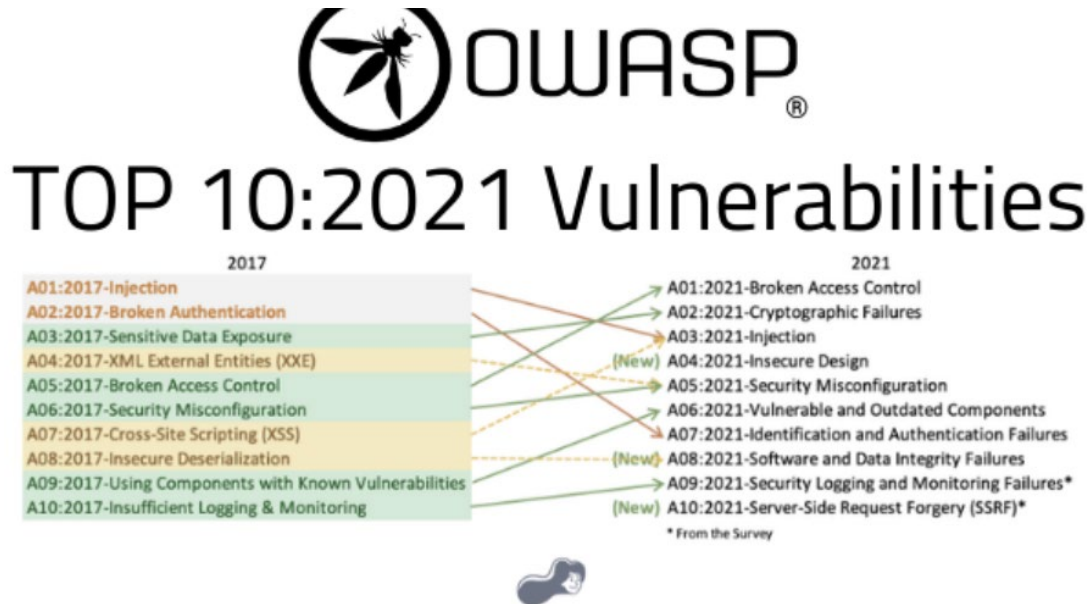


The process – from recognition to remedy and monitoring – represents a continuous cycle. You'll always be one step ahead of attackers.



### 3.4 OWASP

The Open Web Application Security Project (OWASP) is an online community that produces freely-available articles, methodologies, documentation, tools, and technologies in the field of web application security. The Open Web Application Security Project (OWASP) provides free and open resources. It is led by a non-profit called The OWASP Foundation. The OWASP Top 10 - 2021 is the published result of recent research based on comprehensive data compiled from over 40 partner organizations.



### 3.5 BRUTE FORCE

A brute force attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys. It is a simple yet reliable tactic for gaining unauthorized access to individual accounts and organizations' systems and networks. The hacker tries multiple usernames and passwords, often using a computer to test a wide range of combinations, until they find the correct login information.

The name "brute force" comes from attackers using excessively forceful attempts to gain access to user accounts.

Despite being an old cyberattack method, brute force attacks are tried and tested and remain a popular tactic with hackers

#### Applications used in Brute Force Include:

Hydra is a parallelized network login cracker built in various operating systems like Kali Linux, Parrot and other major penetration testing environments. Hydra works by using different approaches to perform brute-force attacks in order to guess the right username and password combination. Hydra is commonly used by penetration testers together with a set of programmes like crunch,[2] cupp[3] etc, which are used to generate wordlists. Hydra is then used to test the attacks using the wordlists that these programmes created.

Over 2.5 Million + Username and password combos are used to Brute force application like RDP, SSH etc.



## 4 INFRASTRUCTURE

### 4.1 Production Server – 41.76.215.242

We have performed two types of scans / attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments.
- Brute Force.

- **Port Mapping - NMAP**

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

| Port   | Protocol | State | Service     | Version                             |
|--------|----------|-------|-------------|-------------------------------------|
| ✓ 22   | tcp      | open  | ssh         | OpenSSH 8.0 (protocol 2.0)          |
| ✓ 80   | tcp      | open  | http        | Apache httpd                        |
| ✓ 111  | tcp      | open  | rpcbind     |                                     |
| ✓ 139  | tcp      | open  | netbios-ssn | Samba smbd                          |
| ✓ 443  | tcp      | open  | http        | Apache httpd                        |
| ✓ 445  | tcp      | open  | netbios-ssn | Samba smbd                          |
| ✓ 1720 | tcp      | open  | h323q931    |                                     |
| ✓ 5432 | tcp      | open  | postgresql  | PostgreSQL DB 9.6.0 or later        |
| ✓ 6001 | tcp      | open  | X11:1       |                                     |
| ✓ 8080 | tcp      | open  | http        | Apache Tomcat (language: en)        |
| ✓ 8443 | tcp      | open  | http        | Apache Tomcat/Coyote JSP engine 1.1 |

#### Remote Operating System Detection:

- Used Port: 22/tcp (open)
- Used Port: 80/tcp (open)
- Used Port: 111/tcp (open)
- Used Port: 139/tcp (open)
- Used Port: 443/tcp (open)
- Used Port: 445/tcp (open)
- Used Port: 1720/tcp (open)
- Used Port: 5432/tcp (open)
- Used Port: 6001/tcp (open)
- Used Port: 8080/tcp (open)
- Used Port: 8443/tcp (open)

- **Vulnerability Assessment - NESSUS**

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:



We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.

**41.76.215.242**



#### Vulnerabilities

Total: 85

| SEVERITY | CVSS V3.0 | VDR SCORE | IPSS SCORE | PLUGIN                 | NAME                                                      |
|----------|-----------|-----------|------------|------------------------|-----------------------------------------------------------|
| CRITICAL | 9.8       | 7.4       | 0.9449     | <a href="#">197839</a> | Apache Tomcat 8.0.0.RC1 < 8.0.39 multiple vulnerabilities |
| CRITICAL | 9.8       | 6.7       | 0.1481     | <a href="#">111067</a> | Apache Tomcat 8.0.0.RC1 < 8.0.53 multiple vulnerabilities |
| CRITICAL | 9.1       | 6.0       | 0.0049     | <a href="#">197850</a> | Apache Tomcat 8.0.0.RC1 < 8.0.37 multiple vulnerabilities |
| CRITICAL | 9.1       | 5.2       | 0.0087     | <a href="#">197857</a> | Apache Tomcat 8.0.0.RC1 < 8.0.42                          |
| CRITICAL | 10.0      | -         | -          | <a href="#">171342</a> | Apache Tomcat SFO (8.0.x)                                 |
| HIGH     | 8.8       | 6.7       | 0.0108     | <a href="#">88937</a>  | Apache Tomcat 8.0.0.RC1 < 8.0.32 multiple vulnerabilities |
| HIGH     | 8.1       | 8.9       | 0.9731     | <a href="#">103697</a> | Apache Tomcat 8.0.0.RC1 < 8.0.47                          |
| HIGH     | 7.5       | 4.4       | 0.2998     | <a href="#">197829</a> | Apache Tomcat 8.0.0.RC1 < 8.0.36                          |
| HIGH     | 7.5       | 3.6       | 0.0146     | <a href="#">197846</a> | Apache Tomcat 8.0.0.RC1 < 8.0.41                          |
| HIGH     | 7.5       | 3.6       | 0.0028     | <a href="#">99367</a>  | Apache Tomcat 8.0.0.RC1 < 8.0.43                          |
| HIGH     | 7.5       | 4.4       | 0.0097     | <a href="#">197837</a> | Apache Tomcat 8.0.0.RC1 < 8.0.44                          |
| HIGH     | 7.5       | 3.6       | 0.0179     | <a href="#">121124</a> | Apache Tomcat 8.0.0.RC1 < 8.0.52                          |
| HIGH     | 7.5       | 5.1       | 0.0398     | <a href="#">42873</a>  | SSL Medium Strength Cipher Suites Supported (SWEET32)     |
| MEDIUM   | 6.5       | 4.4       | 0.0048     | <a href="#">106976</a> | Apache Tomcat 8.0.0.RC1 < 8.0.50 multiple vulnerabilities |
| MEDIUM   | 6.5       | -         | -          | <a href="#">142960</a> | HSTS Missing From HTTPS Server (RFC 6797)                 |
| MEDIUM   | 6.5       | -         | -          | <a href="#">51192</a>  | SSL Certificate Cannot Be Trusted                         |
| MEDIUM   | 5.3       | 1.4       | 0.0034     | <a href="#">83765</a>  | Apache Tomcat 8.0.0-RC1 < 8.0.17                          |
| MEDIUM   | 5.3       | 2.2       | 0.006      | <a href="#">121123</a> | Apache Tomcat 8.0.0.RC1 < 8.0.30                          |
| MEDIUM   | 5.3       | -         | -          | <a href="#">12085</a>  | Apache Tomcat Default Files                               |



|        |      |     |        |        |                                                                |
|--------|------|-----|--------|--------|----------------------------------------------------------------|
| MEDIUM | 4.3  | 2.2 | 0.0027 | 197832 | Apache Tomcat 8.0.0-RC1 < 8.0.27                               |
| MEDIUM | 4.3  | 1.4 | 0.0035 | 102588 | Apache Tomcat 8.0.0-RC1 < 8.0.45                               |
| MEDIUM | 5.0* | -   | -      | 12218  | mDNS Detection (Remote Network)                                |
| LOW    | 3.7  | 1.4 | 0.0015 | 159462 | Apache Tomcat 8.x < 8.5.78 Spring4Shell CVE-2021-43980         |
| LOW    | 3.7  | 6.5 | 0.6016 | 70658  | SSH Server CBC Mode Ciphers Enabled                            |
| LOW    | 3.7  | -   | -      | 153953 | SSH Weak Key Exchange Algorithms Enabled                       |
| LOW    | 3.1  | 2.2 | 0.0133 | 10759  | Web Server HTTP Header Internal IP Disclosure                  |
| LOW    | 2.1* | 2.2 | 0.8939 | 10114  | ICMP Timestamp Request Remote Date Disclosure                  |
| INFO   | N/A  | -   | -      | 10223  | RPC portmapper Service Detection                               |
| INFO   | N/A  | -   | -      | 46180  | Additional DNS Hostnames                                       |
| INFO   | N/A  | -   | -      | 48204  | Apache HTTP Server Version                                     |
| INFO   | N/A  | -   | -      | 159843 | Apache Shiro HTTP Detection                                    |
| INFO   | N/A  | -   | -      | 39446  | Apache Tomcat Detection                                        |
| INFO   | N/A  | -   | -      | 39520  | Backported Security Patch Detection (SSH)                      |
| INFO   | N/A  | -   | -      | 45590  | Common Platform Enumeration (CPE)                              |
| INFO   | N/A  | -   | -      | 84502  | HSTS Missing From HTTPS Server                                 |
| INFO   | N/A  | -   | -      | 43111  | HTTP Methods Allowed (per directory)                           |
| INFO   | N/A  | -   | -      | 10107  | HTTP Server Type and Version                                   |
| INFO   | N/A  | -   | -      | 12053  | Host Fully Qualified Domain Name (FQDN) Resolution             |
| INFO   | N/A  | -   | -      | 24260  | <del>HyperText</del> Transfer Protocol (HTTP) Information      |
| INFO   | N/A  | -   | -      | 46215  | Inconsistent Hostname and IP Address                           |
| INFO   | N/A  | -   | -      | 11011  | Microsoft Windows SMB Service Detection                        |
| INFO   | N/A  | -   | -      | 106716 | Microsoft Windows SMB2 and SMB3 Dialects Supported (rem check) |
| INFO   | N/A  | -   | -      | 11219  | Nessus SYN scanner                                             |
| INFO   | N/A  | -   | -      | 19506  | Nessus Scan Information                                        |





|      |     |   |   |                        |                                                            |
|------|-----|---|---|------------------------|------------------------------------------------------------|
| INFO | N/A | - | - | <a href="#">42823</a>  | Non-compliant Strict Transport Security (STS)              |
| INFO | N/A | - | - | <a href="#">209654</a> | OS Fingerprints Detected                                   |
| INFO | N/A | - | - | <a href="#">11936</a>  | OS Identification                                          |
| INFO | N/A | - | - | <a href="#">117886</a> | OS Security Patch Assessment Not Available                 |
| INFO | N/A | - | - | <a href="#">10919</a>  | Open Port Re-check                                         |
| INFO | N/A | - | - | <a href="#">181418</a> | OpenSSH Detection                                          |
| INFO | N/A | - | - | <a href="#">66334</a>  | Patch Report                                               |
| INFO | N/A | - | - | <a href="#">26024</a>  | PostgreSQL Server Detection                                |
| INFO | N/A | - | - | <a href="#">53335</a>  | RPC portmapper (TCP)                                       |
| INFO | N/A | - | - | <a href="#">31422</a>  | Reverse NAT/Intercepting Proxy Detection                   |
| INFO | N/A | - | - | <a href="#">70657</a>  | SSH Algorithms and Languages Supported                     |
| INFO | N/A | - | - | <a href="#">149334</a> | SSH Password Authentication Accepted                       |
| INFO | N/A | - | - | <a href="#">10881</a>  | SSH Protocol Versions Supported                            |
| INFO | N/A | - | - | <a href="#">153588</a> | SSH SHA-1 HMAC Algorithms Enabled                          |
| INFO | N/A | - | - | <a href="#">10267</a>  | SSH Server Type and Version Information                    |
| INFO | N/A | - | - | <a href="#">56984</a>  | SSL / TLS Versions Supported                               |
| INFO | N/A | - | - | <a href="#">83298</a>  | SSL Certificate Chain Contains Certificates Expiring Soon  |
| INFO | N/A | - | - | <a href="#">42981</a>  | SSL Certificate Expiry - Future Expiry                     |
| INFO | N/A | - | - | <a href="#">10863</a>  | SSL Certificate Information                                |
| INFO | N/A | - | - | <a href="#">95631</a>  | SSL Certificate Signed Using Weak Hashing Algorithm (Known |
| INFO | N/A | - | - | <a href="#">70544</a>  | SSL Cipher Block Chaining Cipher Suites Supported          |
| INFO | N/A | - | - | <a href="#">21643</a>  | SSL Cipher Suites Supported                                |
| INFO | N/A | - | - | <a href="#">57041</a>  | SSL Perfect Forward Secrecy Cipher Suites Supported        |
| INFO | N/A | - | - | <a href="#">94761</a>  | SSL Root Certification Authority Certificate Information   |
| INFO | N/A | - | - | <a href="#">156899</a> | SSL/TLS Recommended Cipher Suites                          |



|      |     |   |   |        |                                                                               |
|------|-----|---|---|--------|-------------------------------------------------------------------------------|
| INFO | N/A | - | - | 22964  | Service Detection                                                             |
| INFO | N/A | - | - | 17975  | Service Detection (GET request)                                               |
| INFO | N/A | - | - | 42822  | Strict Transport Security (STS) Detection                                     |
| INFO | N/A | - | - | 84821  | TLS ALPN Supported Protocol Enumeration                                       |
| INFO | N/A | - | - | 136318 | TLS Version 1.2 Protocol Detection                                            |
| INFO | N/A | - | - | 138330 | TLS Version 1.3 Protocol Detection                                            |
| INFO | N/A | - | - | 110723 | Target Credential Status by Authentication Protocol - No Credentials Provided |
| INFO | N/A | - | - | 10287  | Traceroute Information                                                        |
| INFO | N/A | - | - | 19288  | VNC Server Security Type Detection                                            |
| INFO | N/A | - | - | 65792  | VNC Server Unencrypted Communication Detection                                |
| INFO | N/A | - | - | 10342  | VNC Software Detection                                                        |
| INFO | N/A | - | - | 135860 | WMI Not Available                                                             |
| INFO | N/A | - | - | 100669 | Web Application Cookies Are Expired                                           |
| INFO | N/A | - | - | 20108  | Web Server / Application favicon.ico Vendor Fingerprinting                    |
| INFO | N/A | - | - | 10386  | Web Server No 404 Error Code Check                                            |
| INFO | N/A | - | - | 11422  | Web Server Unconfigured - Default Install Page Present                        |

\* indicates the v3.0 score was not available; the v2.0 score is shown

- Brute Force – HYDRA

Randomised usernames with a word list containing more than 1+ million words and common passwords were brute forced SSH's onto the server using Hydra.

Hydra works by **using different approaches to perform brute-force attacks in order to guess the right username and password combination**. Hydra is commonly used by penetration testers together with a set of programmes like crunch, cupp etc, which are used to generate wordlists.

```
(root@stratix) [~]
# hydra -l mip -P /usr/share/wordlists/dirb/big.txt 41.76.215.242 -t 4 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-04-14 12:46:48
[DATA] max 4 tasks per 1 server, overall 4 tasks, 20469 login tries (l:1/p:20469), ~5118 tries per task
[DATA] attacking ssh://41.76.215.242:22/
[STATUS] 72.00 tries/min, 72 tries in 00:01h, 20397 to do in 04:44h, 4 active
[STATUS] 70.67 tries/min, 212 tries in 00:03h, 20257 to do in 04:47h, 4 active
[STATUS] 69.71 tries/min, 488 tries in 00:07h, 19981 to do in 04:47h, 4 active
[STATUS] 69.60 tries/min, 1044 tries in 00:15h, 19425 to do in 04:40h, 4 active
```



## 4.2 Test Server – 41.76.215.103

We have performed two types of scans/attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter but also include local network.
- Vulnerability assessments.

- **Port Mapping - NMAP**

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

| ▲ | Port | Protocol | State ▲ | Service     | Version                      |
|---|------|----------|---------|-------------|------------------------------|
| ✓ | 22   | tcp      | open    | ssh         | OpenSSH 8.0 (protocol 2.0)   |
| ✓ | 80   | tcp      | open    | http        |                              |
| ✓ | 111  | tcp      | open    | rpcbind     |                              |
| ✓ | 139  | tcp      | open    | netbios-ssn | Samba smbd                   |
| ✓ | 443  | tcp      | open    | https       |                              |
| ✓ | 445  | tcp      | open    | netbios-ssn | Samba smbd                   |
| ✓ | 1028 | tcp      | open    | progress    | Progress Database            |
| ✓ | 1720 | tcp      | open    | h323q931    |                              |
| ✓ | 8080 | tcp      | open    | http        | Apache Tomcat (language: en) |

### Remote Operating System Detection:

- Used Port: 22/tcp (open)
- Used Port: 80/tcp (open)
- Used Port: 111/tcp (open)
- Used Port: 139/tcp (open)
- Used Port: 443/tcp (open)
- Used Port: 445/tcp (open)
- Used Port: 1028/tcp (open)
- Used Port: 1720/tcp (open)
- Used Port: 8080/tcp (open)

- **Vulnerability Assessment - NESSUS**

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.



41.76.215.103



Vulnerabilities

Total: 51

| SEVERITY | CVSS V3.0 | VDR SCORE | IPSS SCORE | PLUGIN | NAME                                                              |
|----------|-----------|-----------|------------|--------|-------------------------------------------------------------------|
| MEDIUM   | 6.5       | -         | -          | 51192  | SSL Certificate Cannot Be Trusted                                 |
| MEDIUM   | 6.5       | -         | -          | 57582  | SSL Self-Signed Certificate                                       |
| LOW      | 3.7       | 6.5       | 0.6016     | 70658  | SSH Server CBC Mode Ciphers Enabled                               |
| LOW      | 3.7       | -         | -          | 153953 | SSH Weak Key Exchange Algorithms Enabled                          |
| LOW      | 3.1       | 2.2       | 0.0133     | 10759  | Web Server HTTP Header Internal IP Disclosure                     |
| LOW      | 2.1*      | 2.2       | 0.8939     | 10114  | ICMP Timestamp Request Remote Date Disclosure                     |
| INFO     | N/A       | -         | -          | 10223  | RPC portmapper Service Detection                                  |
| INFO     | N/A       | -         | -          | 159843 | Apache Shiro HTTP Detection                                       |
| INFO     | N/A       | -         | -          | 39446  | Apache Tomcat Detection                                           |
| INFO     | N/A       | -         | -          | 39520  | Backported Security Patch Detection (SSH)                         |
| INFO     | N/A       | -         | -          | 45590  | Common Platform Enumeration (CPE)                                 |
| INFO     | N/A       | -         | -          | 84502  | HSTS Missing From HTTPS Server                                    |
| INFO     | N/A       | -         | -          | 43111  | HTTP Methods Allowed (per directory)                              |
| INFO     | N/A       | -         | -          | 12053  | Host Fully Qualified Domain Name (FQDN) Resolution                |
| INFO     | N/A       | -         | -          | 24260  | <del>HyperText</del> Transfer Protocol (HTTP) Information         |
| INFO     | N/A       | -         | -          | 11011  | Microsoft Windows SMB Service Detection                           |
| INFO     | N/A       | -         | -          | 106716 | Microsoft Windows SMB2 and SMB3 Dialects Supported (remote check) |
| INFO     | N/A       | -         | -          | 11219  | Nessus SYN scanner                                                |



|      |     |   |   |        |                                                     |
|------|-----|---|---|--------|-----------------------------------------------------|
| INFO | N/A | - | - | 19506  | Nessus Scan Information                             |
| INFO | N/A | - | - | 42823  | Non-compliant Strict Transport Security (STS)       |
| INFO | N/A | - | - | 209654 | OS Fingerprints Detected                            |
| INFO | N/A | - | - | 11936  | OS Identification                                   |
| INFO | N/A | - | - | 117886 | OS Security Patch Assessment Not Available          |
| INFO | N/A | - | - | 181418 | OpenSSH Detection                                   |
| INFO | N/A | - | - | 53335  | RPC portmapper (TCP)                                |
| INFO | N/A | - | - | 31422  | Reverse NAT/Intercepting Proxy Detection            |
| INFO | N/A | - | - | 70657  | SSH Algorithms and Languages Supported              |
| INFO | N/A | - | - | 149334 | SSH Password Authentication Accepted                |
| INFO | N/A | - | - | 10881  | SSH Protocol Versions Supported                     |
| INFO | N/A | - | - | 153588 | SSH SHA-1 HMAC Algorithms Enabled                   |
| INFO | N/A | - | - | 10267  | SSH Server Type and Version Information             |
| INFO | N/A | - | - | 56984  | SSL / TLS Versions Supported                        |
| INFO | N/A | - | - | 45410  | SSL Certificate 'commonName' Mismatch               |
| INFO | N/A | - | - | 10863  | SSL Certificate Information                         |
| INFO | N/A | - | - | 70544  | SSL Cipher Block Chaining Cipher Suites Supported   |
| INFO | N/A | - | - | 21643  | SSL Cipher Suites Supported                         |
| INFO | N/A | - | - | 57041  | SSL Perfect Forward Secrecy Cipher Suites Supported |
| INFO | N/A | - | - | 156899 | SSL/TLS Recommended Cipher Suites                   |
| INFO | N/A | - | - | 22964  | Service Detection                                   |
| INFO | N/A | - | - | 17975  | Service Detection (GET request)                     |
| INFO | N/A | - | - | 42822  | Strict Transport Security (STS) Detection           |
| INFO | N/A | - | - | 84821  | TLS ALPN Supported Protocol Enumeration             |
| INFO | N/A | - | - | 136318 | TLS Version 1.2 Protocol Detection                  |



|      |     |   |   |        |                                                                               |
|------|-----|---|---|--------|-------------------------------------------------------------------------------|
| INFO | N/A | - | - | 138330 | TLS Version 1.3 Protocol Detection                                            |
| INFO | N/A | - | - | 110723 | Target Credential Status by Authentication Protocol - No Credentials Provided |
| INFO | N/A | - | - | 10287  | Traceroute Information                                                        |
| INFO | N/A | - | - | 11154  | Unknown Service Detection: Banner Retrieval                                   |
| INFO | N/A | - | - | 135860 | WMI Not Available                                                             |
| INFO | N/A | - | - | 100669 | Web Application Cookies Are Expired                                           |
| INFO | N/A | - | - | 20108  | Web Server / Application favicon.ico Vendor Fingerprinting                    |
| INFO | N/A | - | - | 10386  | Web Server No 404 Error Code Check                                            |

\* indicates the v3.0 score was not available; the v2.0 score is shown

### 4.3 VP Server – 41.76.215.103

We have performed two types of scans / attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments.

#### • Port Mapping – NMAP

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

| ▲ | Port | Protocol | State ▲ | Service    | Version                      |
|---|------|----------|---------|------------|------------------------------|
| ✓ | 22   | tcp      | open    | ssh        | OpenSSH 8.0 (protocol 2.0)   |
| ✓ | 1720 | tcp      | open    | h323q931   |                              |
| ✓ | 5432 | tcp      | open    | postgresql | PostgreSQL DB 9.6.0 or later |
| ✓ | 8443 | tcp      | open    | http       | Apache Tomcat 9.0.85         |

#### Remote Operating System Detection:

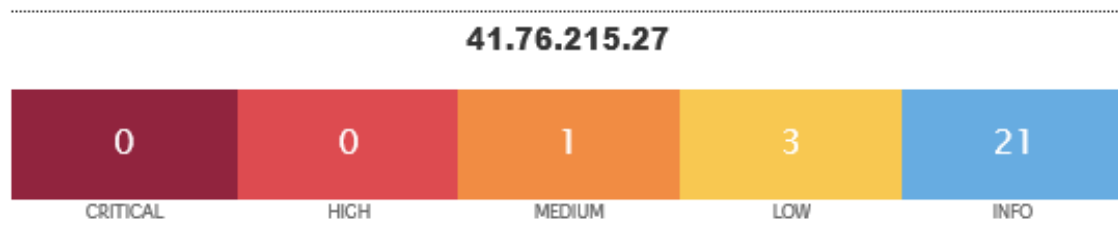
- Used Port: 22/tcp (open)
- Used Port: 1720/tcp (open)
- Used Port: 5432/tcp (open)
- Used Port: 8443/tcp (open)



- Vulnerability Assessment - NESSUS

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.



Vulnerabilities

Total: 25

| SEVERITY | CVSS V3.0 | VDR SCORE | IPSS SCORE | PLUGIN                 | NAME                                                      |
|----------|-----------|-----------|------------|------------------------|-----------------------------------------------------------|
| MEDIUM   | 5.9       | 6.1       | 0.9538     | <a href="#">187315</a> | SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)  |
| LOW      | 3.7       | 6.5       | 0.6016     | <a href="#">70658</a>  | SSH Server CBC Mode Ciphers Enabled                       |
| LOW      | 3.7       | -         | -          | <a href="#">153953</a> | SSH Weak Key Exchange Algorithms Enabled                  |
| LOW      | 2.1*      | 2.2       | 0.8939     | <a href="#">10114</a>  | ICMP Timestamp Request Remote Date Disclosure             |
| INFO     | N/A       | -         | -          | <a href="#">39520</a>  | Backported Security Patch Detection (SSH)                 |
| INFO     | N/A       | -         | -          | <a href="#">45590</a>  | Common Platform Enumeration (CPE)                         |
| INFO     | N/A       | -         | -          | <a href="#">12053</a>  | Host Fully Qualified Domain Name (FQDN) Resolution        |
| INFO     | N/A       | -         | -          | <a href="#">24260</a>  | <del>HyperText</del> Transfer Protocol (HTTP) Information |
| INFO     | N/A       | -         | -          | <a href="#">11219</a>  | Nessus SYN scanner                                        |
| INFO     | N/A       | -         | -          | <a href="#">19506</a>  | Nessus Scan Information                                   |
| INFO     | N/A       | -         | -          | <a href="#">209654</a> | OS Fingerprints Detected                                  |
| INFO     | N/A       | -         | -          | <a href="#">11936</a>  | OS Identification                                         |
| INFO     | N/A       | -         | -          | <a href="#">117886</a> | OS Security Patch Assessment Not Available                |
| INFO     | N/A       | -         | -          | <a href="#">181418</a> | OpenSSH Detection                                         |
| INFO     | N/A       | -         | -          | <a href="#">66334</a>  | Patch Report                                              |
| INFO     | N/A       | -         | -          | <a href="#">31422</a>  | Reverse NAT/Intercepting Proxy Detection                  |
| INFO     | N/A       | -         | -          | <a href="#">70657</a>  | SSH Algorithms and Languages Supported                    |
| INFO     | N/A       | -         | -          | <a href="#">149334</a> | SSH Password Authentication Accepted                      |
| INFO     | N/A       | -         | -          | <a href="#">10881</a>  | SSH Protocol Versions Supported                           |





|      |     |   |   |        |                                                                               |
|------|-----|---|---|--------|-------------------------------------------------------------------------------|
| INFO | N/A | - | - | 153588 | SSH SHA-1 HMAC Algorithms Enabled                                             |
| INFO | N/A | - | - | 10267  | SSH Server Type and Version Information                                       |
| INFO | N/A | - | - | 22964  | Service Detection                                                             |
| INFO | N/A | - | - | 110723 | Target Credential Status by Authentication Protocol - No Credentials Provided |
| INFO | N/A | - | - | 10287  | Traceroute Information                                                        |
| INFO | N/A | - | - | 11154  | Unknown Service Detection: Banner Retrieval                                   |

\* indicates the v3.0 score was not available; the v2.0 score is shown

#### 4.4 ODS Server – 41.76.213.162

We have performed two types of scans/attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter but also include local network.
- Vulnerability assessments.

- Port Mapping - NMAP

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

| Nmap Output |      | Ports / Hosts |         | Topology   | Host Details                 | Scans |
|-------------|------|---------------|---------|------------|------------------------------|-------|
| ▲           | Port | Protocol      | State ▲ | Service    | Version                      |       |
| ✓           | 22   | tcp           | open    | ssh        | OpenSSH 8.0 (protocol 2.0)   |       |
| ✓           | 1720 | tcp           | open    | h323q931   |                              |       |
| ✓           | 5432 | tcp           | open    | postgresql | PostgreSQL DB 9.6.0 or later |       |
| ✓           | 8443 | tcp           | open    | http       | Apache Tomcat 9.0.85         |       |

#### Remote Operating System Detection:

- Used Port: 22/tcp (open)
- Used Port: 1720/tcp (open)
- Used Port: 5432/tcp (open)
- Used Port: 8443/tcp (open)

- Vulnerability Assessment - NESSUS

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:





We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.

**41.76.213.162**



Vulnerabilities

Total: 48

| SEVERITY | CVSS V3.0 | VDR SCORE | IPSS SCORE | PLUGIN                 | NAME                                                      |
|----------|-----------|-----------|------------|------------------------|-----------------------------------------------------------|
| CRITICAL | 9.8       | 9.4       | 0.0004     | <a href="#">213078</a> | Apache Tomcat 9.0.0.M1 < 9.0.98 multiple vulnerabilities  |
| CRITICAL | 9.1       | 8.3       | 0.0004     | <a href="#">232528</a> | Apache Tomcat 9.0.0.M1 < 9.0.99                           |
| HIGH     | 7.5       | 3.6       | 0.0004     | <a href="#">201848</a> | Apache Tomcat 9.0.0.M1 < 9.0.90                           |
| MEDIUM   | 6.3       | 4.4       | 0.0004     | <a href="#">192042</a> | Apache Tomcat 9.0.0.M1 < 9.0.86 multiple vulnerabilities  |
| MEDIUM   | 5.9       | 6.1       | 0.9538     | <a href="#">187315</a> | SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)  |
| MEDIUM   | 5.3       | -         | -          | <a href="#">12085</a>  | Apache Tomcat Default Files                               |
| LOW      | 3.7       | 6.5       | 0.6016     | <a href="#">70658</a>  | SSH Server CBC Mode Ciphers Enabled                       |
| LOW      | 3.7       | -         | -          | <a href="#">153953</a> | SSH Weak Key Exchange Algorithms Enabled                  |
| LOW      | 2.1*      | 2.2       | 0.8939     | <a href="#">10114</a>  | ICMP Timestamp Request Remote Date Disclosure             |
| INFO     | N/A       | -         | -          | <a href="#">39446</a>  | Apache Tomcat Detection                                   |
| INFO     | N/A       | -         | -          | <a href="#">39520</a>  | Backported Security Patch Detection (SSH)                 |
| INFO     | N/A       | -         | -          | <a href="#">45590</a>  | Common Platform Enumeration (CPE)                         |
| INFO     | N/A       | -         | -          | <a href="#">54615</a>  | Device Type                                               |
| INFO     | N/A       | -         | -          | <a href="#">84502</a>  | HSTS Missing From HTTPS Server                            |
| INFO     | N/A       | -         | -          | <a href="#">43111</a>  | HTTP Methods Allowed (per directory)                      |
| INFO     | N/A       | -         | -          | <a href="#">12053</a>  | Host Fully Qualified Domain Name (FQDN) Resolution        |
| INFO     | N/A       | -         | -          | <a href="#">24260</a>  | <del>HyperText</del> Transfer Protocol (HTTP) Information |
| INFO     | N/A       | -         | -          | <a href="#">46215</a>  | Inconsistent Hostname and IP Address                      |
| INFO     | N/A       | -         | -          | <a href="#">11219</a>  | Nessus SYN scanner                                        |



|      |     |   |   |        |                                                                               |
|------|-----|---|---|--------|-------------------------------------------------------------------------------|
| INFO | N/A | - | - | 19506  | Nessus Scan Information                                                       |
| INFO | N/A | - | - | 209654 | OS Fingerprints Detected                                                      |
| INFO | N/A | - | - | 11936  | OS Identification                                                             |
| INFO | N/A | - | - | 117886 | OS Security Patch Assessment Not Available                                    |
| INFO | N/A | - | - | 181418 | OpenSSH Detection                                                             |
| INFO | N/A | - | - | 66334  | Patch Report                                                                  |
| INFO | N/A | - | - | 26024  | PostgreSQL Server Detection                                                   |
| INFO | N/A | - | - | 70657  | SSH Algorithms and Languages Supported                                        |
| INFO | N/A | - | - | 149334 | SSH Password Authentication Accepted                                          |
| INFO | N/A | - | - | 10881  | SSH Protocol Versions Supported                                               |
| INFO | N/A | - | - | 153588 | SSH SHA-1 HMAC Algorithms Enabled                                             |
| INFO | N/A | - | - | 10267  | SSH Server Type and Version Information                                       |
| INFO | N/A | - | - | 56984  | SSL / TLS Versions Supported                                                  |
| INFO | N/A | - | - | 45410  | SSL Certificate 'commonName' Mismatch                                         |
| INFO | N/A | - | - | 83298  | SSL Certificate Chain Contains Certificates Expiring Soon                     |
| INFO | N/A | - | - | 42981  | SSL Certificate Expiry - Future Expiry                                        |
| INFO | N/A | - | - | 10863  | SSL Certificate Information                                                   |
| INFO | N/A | - | - | 95631  | SSL Certificate Signed Using Weak Hashing Algorithm (Known                    |
| INFO | N/A | - | - | 70544  | SSL Cipher Block Chaining Cipher Suites Supported                             |
| INFO | N/A | - | - | 21643  | SSL Cipher Suites Supported                                                   |
| INFO | N/A | - | - | 57041  | SSL Perfect Forward Secrecy Cipher Suites Supported                           |
| INFO | N/A | - | - | 94761  | SSL Root Certification Authority Certificate Information                      |
| INFO | N/A | - | - | 156899 | SSL/TLS Recommended Cipher Suites                                             |
| INFO | N/A | - | - | 22964  | Service Detection                                                             |
| INFO | N/A | - | - | 25220  | TCP/IP Timestamps Supported                                                   |
| INFO | N/A | - | - | 136318 | TLS Version 1.2 Protocol Detection                                            |
| INFO | N/A | - | - | 138330 | TLS Version 1.3 Protocol Detection                                            |
| INFO | N/A | - | - | 110723 | Target Credential Status by Authentication Protocol - No Credentials Provided |
| INFO | N/A | - | - | 10287  | Traceroute Information                                                        |

\* indicates the v3.0 score was not available; the v2.0 score is shown



## 5 REPORTING CONCLUSION

Based on the OWASP reports it is best to attach these separate to the reporting document. These reports can then be shared with the relevant contractors and/or support personnel to implement the changes and updates.

It is our view that from External Testing where the SSH port are not open to public, these vulnerabilities then become academic. However, we still recommend that the changes be implemented. Unity Health is behind the managed FortiGate firewall. Not even the public network can exploit the SSH vulnerabilities

The HTTPS updates as these are open to the public, low and medium risk, should be tested and implemented as soon as possible.

From a hosted infrastructure point of view, we are happy with the public external scan.

Eighteen (18) addendum reports are attached to this report and should be read as one document.

Two separate folders are included:

### **Folder 1: Public IP Scan – Main**

Contains scan results performed directly from a public IP to target public IP addresses.

### **Folder 2: Internal IP Scan – Main**

Contains scan results from allowed public IPs to internal production server IPs

With the following test performed:

- Network scanning
- IDS/IPS disabled
- Knows network attack (from Internet to the FW)
- External HTTP and Port exploits
- Vulnerability assessment on CVE
- Penetration testing on login ports i.e.: ssh open

## 6 AUDITORS

These audits were concluded over a period of seven (7) days.  
We hereby confirm that the above information is true and correct:

25<sup>th</sup> April 2025 – Krugersdorp, South Africa

  
\_\_\_\_\_  
Riaan van Jaarsveld  
Security Expert – CCSA / Certified Pen Tester

  
\_\_\_\_\_  
Lukas van Rensburg  
Security Engineer